Bug Bounty Workflow + CTF Practice + Reporting

Agenda

- Introduction to Bug Bounties
- Bug Bounty Workflow
- CTF (Capture The Flag) Practice
- Reporting & Documentation
- Best Practices & Tips

Introduction to Bug Bounties

Definition: Programs where companies reward security researchers for finding vulnerabilities.

Purpose:

- Improve product security
- Encourage ethical hacking
- Reduce cyber risk

Platforms:

- HackerOne
- Bugcrowd
- Intigriti
- Synack

Bug Bounty Workflow Overview

- Reconnaissance
- Vulnerability Discovery
- Exploitation & Proof of Concept (PoC)
- Documentation
- Submission & Follow-Up



Step 1 – Reconnaissance

Goal: Gather as much information about the target as possible.

Techniques:

- Subdomain Enumeration (Amass, Subfinder)
- Directory Bruteforcing (Gobuster, Dirsearch)
- Technology Stack Identification (Wappalyzer, BuiltWith)
- OSINT (Google Dorking, Shodan, WHOIS)

Output: Target map, possible attack surface.



Step 2 – Vulnerability Discovery

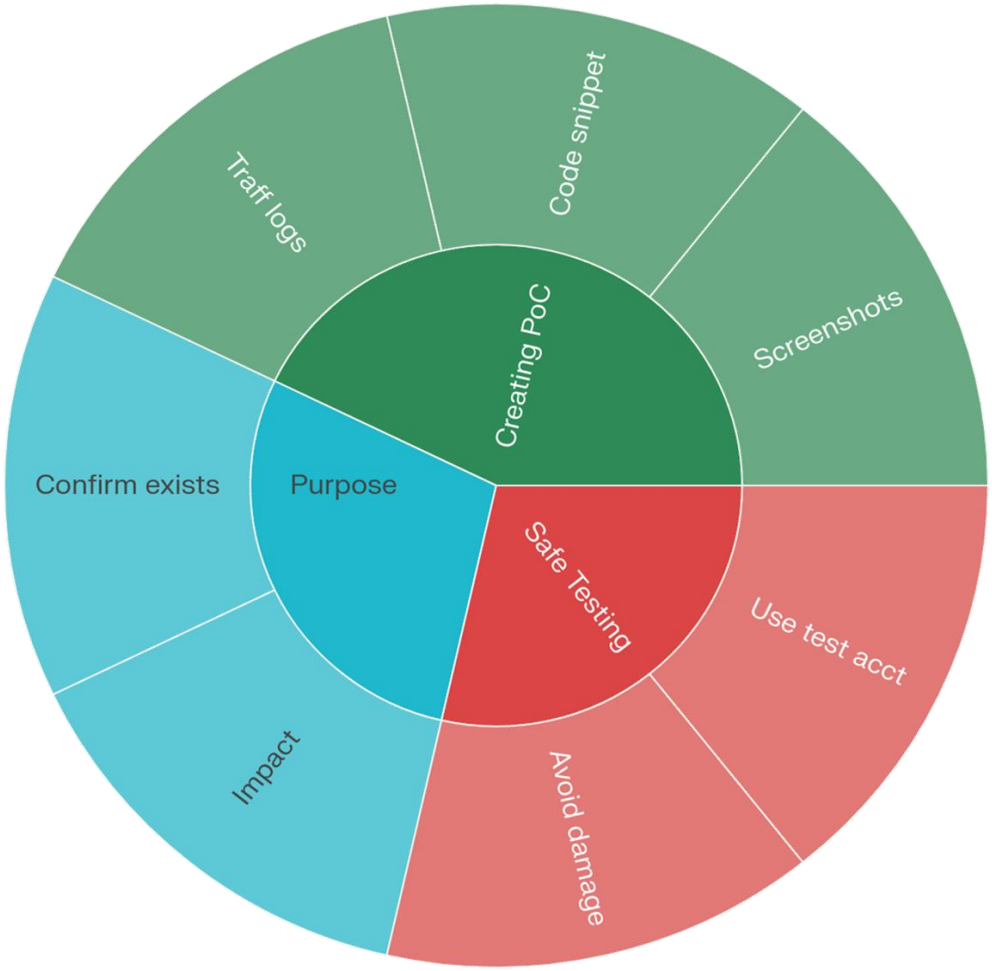
Manual Testing	Automated Scanning	Common Vulnerabilities
Input validation	Acunetix Scanner	XSS (Cross-Site Scripting)
Authentication checks	Nmap (service discovery & vulnerability scripts)	SQL Injection
Session management flaws		CSRF (Cross-Site Request Forgery)
		IDOR (Insecure Direct Object Reference)
		SSRF (Server-Side Request Forgery)
		RCE (Remote Code Execution

Step 3 – Exploitation & PoC

Purpose: Confirm the vulnerability exists and understand its impact.

Safe Testing:
- Avoid production damage
- Use test accounts where possible

Creating PoC:
- Screenshots
- Network traffic logs (Burp, Wireshark)
- Code snippets

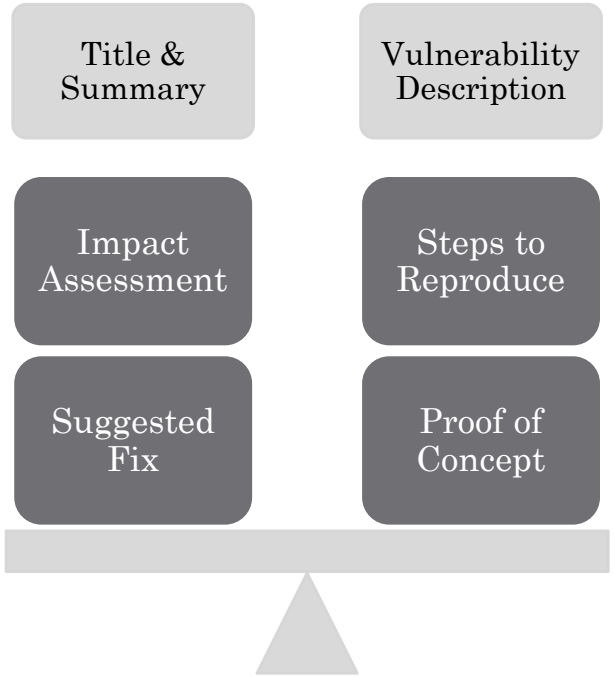


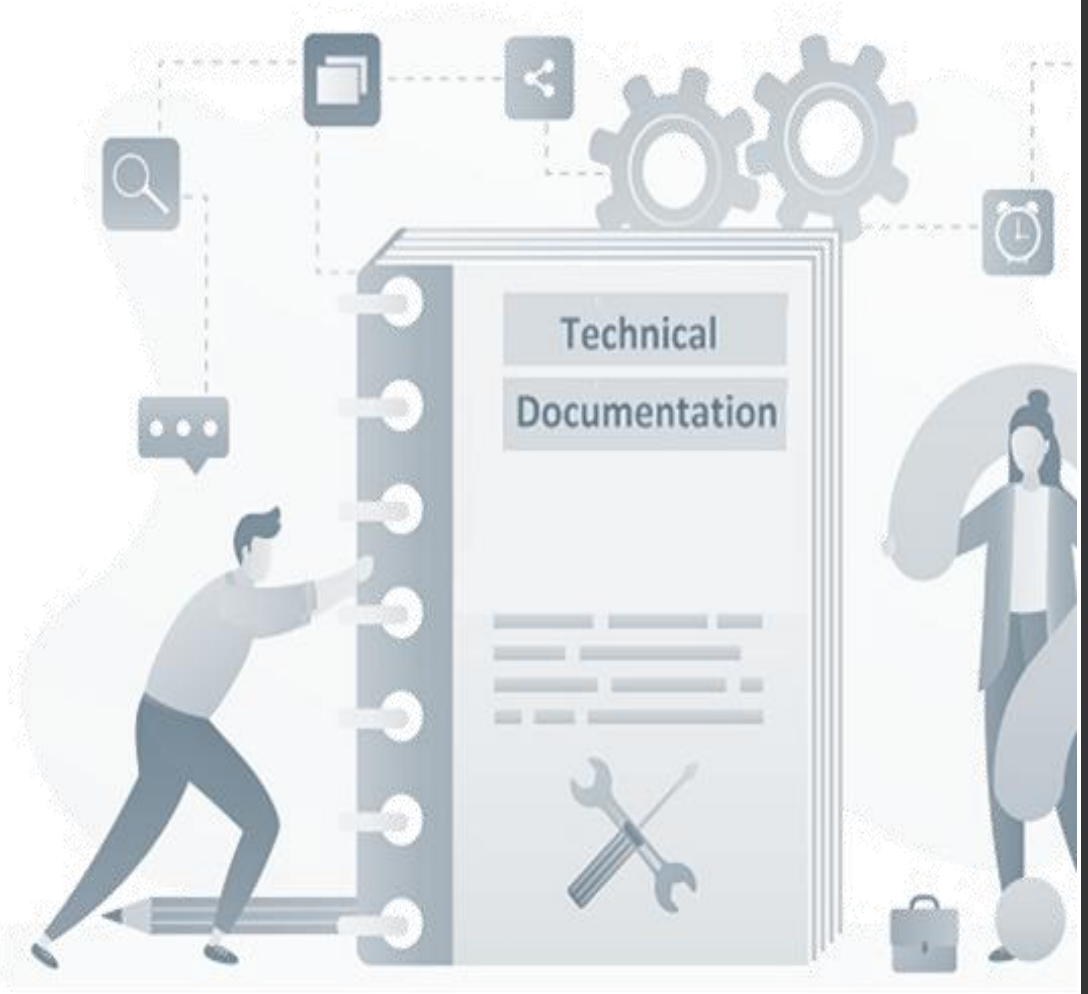
Step 4 – Documentation & Reporting

Why Documentation is Important:

- Clear communication with security teams
- Faster triage & resolution

Key Elements:





Step 5 – Submission & Follow-Up

Submit via bug bounty platform portal.

Tips:

- Be clear and concise: Briefly explain the vulnerability and its impact.
- **Attach proof:** Include screenshots, code snippets, or logs that show the issue.
- **Follow up quickly:** Respond politely and promptly to any questions.
- **Stay professional:** Keep communication respectful and focused on facts.

Follow-Up:

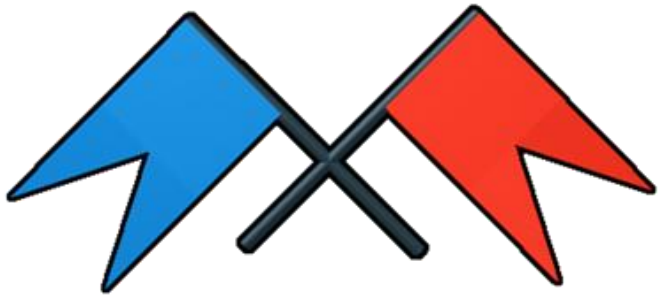
- Respond promptly to clarifications.
- Maintain professionalism

Introduction to CTFs

Definition: Cybersecurity competitions where players solve challenges to "capture flags."

Benefits for Bug Bounty Hunters:

- Skill building in web, network, reverse engineering, cryptography
- Learn new exploitation techniques
- Improve problem-solving speed



CTF

CAPTURE THE FLAG

CTF Practice Workflow

- Choose a CTF Platform (TryHackMe, HackTheBox, PicoCTF)
- Pick a Category (Web, Crypto, Pwn, Forensics)
- Analyze the Challenge
- Exploit & Extract Flag
- Document the Solution

Tools & Skills for CTF

Category	Items	Description
Tools	Burp Suite	Web vulnerability scanner and proxy for security testing.
	Wireshark	Network protocol analyzer to capture and inspect network traffic.
	Ghidra / IDA	Reverse engineering tools for analyzing compiled software and malware.
	John the Ripper / Hashcat	Password cracking tools used for testing password strength and hash recovery.
Skills	Scripting (Python, Bash)	Automating tasks, writing custom tools, and parsing data.
	Regular Expressions	Pattern matching for searching and extracting information from text/logs.
	Reverse Engineering	Understanding and analyzing compiled code or binaries.
	Networking Basics	Knowledge of network protocols, traffic, and security concepts.

Reporting in Bug Bounty & CTF

Bug Bounty Reports

- Professional and well-structured
- Provide clear, actionable information

CTF Writeups

- Educational with step-by-step explanations
- Include tools used and reasoning behind each step

Common Mistakes to Avoid

- Missing reproduction steps
- Vague descriptions of the impact
- Lack of proof of concept (PoC) evidence

Best Practices

Understand the Rules:	Always read and follow the program scope before starting tests.
Test Responsibly:	Avoid testing in production unless explicitly permitted.
Keep Tools Updated:	Regularly update security tools for best performance and protection.
Continuous Learning:	Study public writeups to learn new techniques and approaches.
Practice, Practice, Practice:	Sharpen skills regularly via Capture The Flag (CTF) challenges.

References & Resources

Bug Bounty and Hacker Community Platforms

- HackerOne Hacktivity
- Bugcrowd University

Web and Application Security Guides

- OWASP Testing Guide
- PortSwigger Web Security Academy

Hands-On Labs and Practice Platforms

- TryHackMe
- HackTheBox